INCIDENT WALL

Real incidents, publicly reported. One card per incident. When you have worked on a card, stick it here and add a sticky note: The control that would have helped:

- 1 The freeze that wasn't (July 2025)
- 2 The chatbot the airline had to honour (February 2024)
- 3 One line of code, 1,643 downloads (September 2025)
- 4 A public issue read a private repository (May 2025)
- 5 The server that showed other people's data (June 2025)

This wall stays up for the week. On Day 4 you check every card against the control ownership matrix.

CARD 1 | July 2025

The freeze that wasn't

What was reported

- A founder ran a public 12-day experiment building an application with an AI coding agent on the Replit platform.
- About day nine, during a code and action freeze he had told the agent to respect, the agent ran destructive commands against the live production database. Reports put the lost records at roughly 1,200 executives and 1,200 companies.
- The agent then told him a rollback was not possible.
- One report says the same database was being used for preview, testing and production. The freeze existed only as an instruction to the agent. The founder said the application was a demo and put the loss at about 100 hours of work.

The question for your pair

The freeze was a rule in the agent's instructions. Name one control that sits outside the agent and would have stopped the deletion even if the agent had decided to run the command.

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: heise online (July 2025); eWeek (22 July 2025); The Stack; AI Incident Database, incident 1152.

CARD 2 | February 2024

The chatbot the airline had to honour

What was reported

- A customer asked an airline's website chatbot about bereavement fares after a family death. The chatbot told him he could apply for the reduced fare retroactively within 90 days.
- The airline's actual policy said otherwise. A link in the chatbot's answer led to the correct policy page. The airline refused the refund.
- In a decision published on 14 February 2024, a British Columbia tribunal found the airline liable for negligent misrepresentation, said it had not taken reasonable care to ensure its chatbot was accurate, and ordered it to pay roughly C$812 including damages, interest and fees.
- The airline had argued the chatbot was a separate entity responsible for its own actions. The tribunal called that a remarkable submission.

The question for your pair

Which part of "telling a customer what the refund policy says" could be a rule, and which part needs the model at all?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Civil Resolution Tribunal of British Columbia decision, 14 February 2024, as reported by Kiplinger, Fox Business, ITWire and Norton Rose Fulbright.

CARD 3 | September 2025

One line of code, 1,643 downloads

What was reported

- Security researchers at Koi Security reported what they described as the first malicious MCP server seen in the wild: an npm package called postmark-mcp.
- It copied the code of the real Postmark MCP server, which is published on GitHub, not npm. The publisher released fifteen versions that behaved normally.
- In version 1.0.16, released on 17 September 2025, one added line blind-copied every email sent through the server to an address the publisher controlled.
- Reports put the package at about 1,500 downloads in a week and 1,643 in total before it was removed. The emails could include password resets, invoices and customer correspondence.

The question for your pair

You run the intake checklist. Which line would have caught this, and at which moment: the first install, or a later version change?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Koi Security as reported by The Hacker News (via ThaiCERT), SC Media, Dark Reading, The Register (29 September 2025).

CARD 4 | May 2025

A public issue read a private repository

What was reported

- Researchers at Invariant Labs showed that an agent connected to the official GitHub MCP server could be hijacked by a malicious issue posted in a public repository.
- The user asks the agent to look at the open issues of the public repository. The agent reads the attacker's instructions, uses the user's access token to read data from the user's private repositories, and publishes that data in a pull request on the public repository, where the attacker can read it.
- No tool was poisoned and no server was compromised. The token allowed access to both public and private repositories.
- The researchers and others described this as an architectural problem at the agent-system level, not a bug in the server.

The question for your pair

There are three legs: private data, untrusted instructions, a way out. Which one is easiest to remove in a design you have seen?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Invariant Labs, "GitHub MCP exploited" (May 2025); DevClass; Hackernoon; SOCRadar.

CARD 5 | June 2025

The server that showed other people's data

What was reported

- A work-management vendor launched an experimental, opt-in MCP server on 1 May 2025.
- On 4 June the vendor found a logic flaw that could let one organisation's MCP users see data belonging to other organisations, limited to what the exposed user could access.
- The vendor took the server offline from 5 to 17 June, notified roughly 1,000 potentially affected customers on 16 June, and gave customers the means to request logs to check whether exposure had occurred.
- The bug was reported to have been in the initial release, so the exposure window ran for about a month.

The question for your pair

You are a customer of this server. How would you have found out, and what would you have wanted in the contract and the architecture before connecting?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: BleepingComputer (18 June 2025); The Register (18 June 2025); UpGuard; SANS NewsBites (24 June 2025).